

CERTIFICATI DIGITALI

Come funziona la fiducia nel mondo digitale



Il problema: come fidarsi?



Lo scenario

Anna vuole mandare un messaggio sicuro a Bruno.

Bruno riceve la chiave pubblica di Anna... ma come fa a sapere che è davvero sua?

Un attaccante potrebbe essersi sostituito ad Anna — questo si chiama attacco Man-in-the-Middle.



La soluzione

La chiave pubblica viene "confezionata" all'interno di un **certificato digitale**.

Il certificato è firmato da un ente terzo di fiducia chiamato **Certification Authority (CA)**, che garantisce l'identità del mittente.

Cos'è un certificato digitale?

Un certificato digitale è un documento informatico che attesta l'associazione univoca tra una chiave pubblica e l'identità di un soggetto (persona, organizzazione o sistema).



L'analogia più semplice

Carta d'identità



Associa un volto a un nome, emessa da uno Stato che ne garantisce la veridicità

Certificato digitale



Associa una chiave pubblica a un'identità, emesso da una CA che ne garantisce la veridicità

Cosa contiene un certificato?



Dati del proprietario

- Nome e cognome
- Data di nascita
- Chiave pubblica



Dati del certificato

- Data di scadenza
- Numero di serie
- Formato (es. X.509)



Dati della CA

- Ragione sociale del certificatore
- Codice identificativo del titolare
- Firma digitale della CA



Una coppia di chiavi a 1024 bit ha validità massima di 2 anni — i certificati vanno periodicamente rinnovati.

La Certification Authority (CA)

Cos'è la CA?

La Certification Authority è un ente (pubblico o privato accreditato) che garantisce l'identità del titolare di un certificato.

Lo fa firmando le chiavi pubblica e privata del richiedente con la propria chiave privata, rendendo impossibile la manomissione.

Per violare un certificato un attaccante dovrebbe:

1. Violare la cifratura della CA
2. Sostituire le chiavi con chiavi false
3. Ri-firmare tutto con la chiave privata della CA

→ Praticamente impossibile!

CA italiane (esempio)

- Infocamere Spa
- Postecom Spa
- Trust Italia Spa
- ENEL.IT Spa
- BNL Multiservizi Spa
- Aruba PEC Spa

Registration Authority vs Certification Authority



Registration Authority (RA)

Si occupa di verificare l'identità del richiedente prima che il certificato venga emesso.

- Raccoglie i dati del richiedente
- Verifica nome, dominio, P.IVA ecc.
- Può richiedere documenti aggiuntivi
- Attiva la procedura di identificazione



Certification Authority (CA)

Si occupa del ciclo di vita del certificato: emissione, pubblicazione, manutenzione.

- Genera il certificato digitale
- Lo firma con la propria chiave privata
- Lo pubblica nel repository online
- Gestisce revoca e rinnovo

PKI - Public Key Infrastructure

La PKI (Public Key Infrastructure) è l'insieme di tutte le parti, tecnologie, servizi e politiche di gestione che rendono possibile la creazione, distribuzione e revoca sicura dei certificati di chiave pubblica.



Utenti, aziende, enti pubblici e privati che usano i certificati

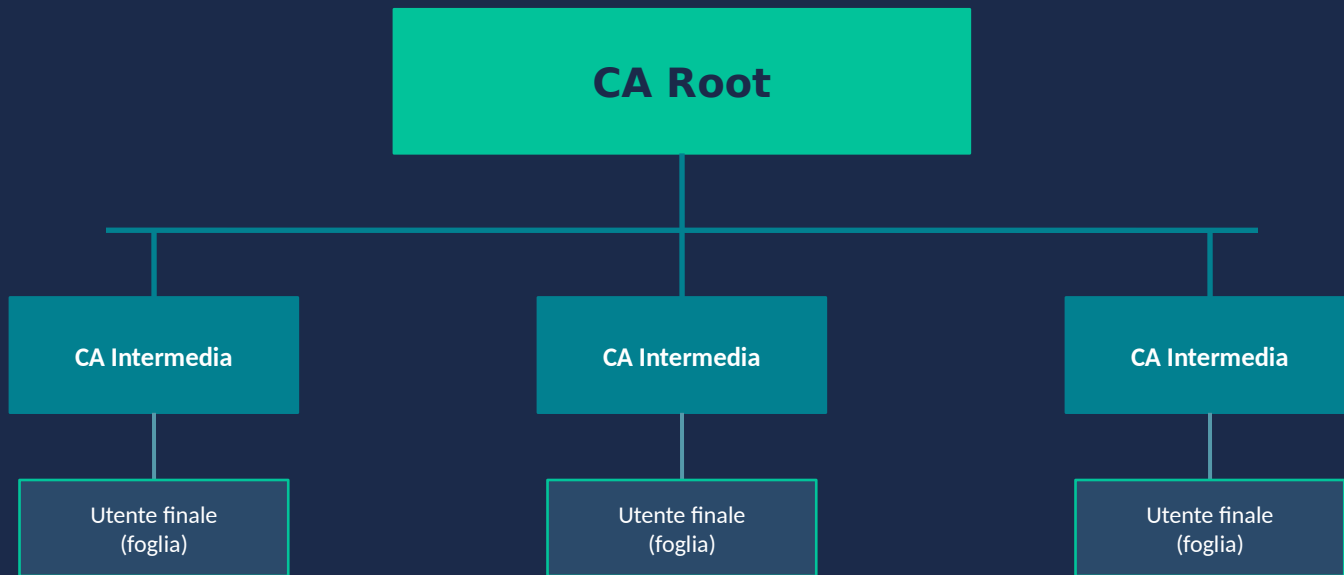


Algoritmi crittografici (RSA, SHA), standard X.509, protocolli TLS/SSL



Regole di emissione, validazione, rinnovo e revoca dei certificati

Come è strutturata la catena di fiducia



CA Root → ente radice, la massima autorità di fiducia

CA Intermedia → firma i certificati di aziende e utenti finali

Foglie → utenti, siti web, software che usano il certificato

Come si ottiene un certificato digitale?



Formati dei certificati: X.509 e PGP/GPG



X.509

Standard internazionale (ITU-T/IETF)

- Richiede una CA accreditata
- Massima interoperabilità
- Usato in HTTPS, TLS/SSL, email S/MIME
- Formato .p7m riconosciuto dalla PA
- Obbligatorio per documenti legali in Italia



PGP / GPG

Rete di fiducia distribuita (Web of Trust)

- Creabile autonomamente in pochi istanti
- Nessuna CA necessaria
- Usato per email cifrate e software
- Meno adatto a contesti istituzionali
- Più flessibile ma meno controllato

La differenza fondamentale: PGP si può creare da soli, X.509 richiede una CA.

Revoca dei certificati: CRL e OCSP

Perché si revoca un certificato?

- La chiave privata è stata compromessa
- La chiave privata è andata persa
- Il titolare non è più autorizzato (es. licenziato)
- Semplice scadenza temporale

CRL - Certificate Revocation List

Lista pubblica dei certificati revocati, pubblicata e aggiornata dalla CA. Prima di fidarsi di un certificato è buona norma verificare che il suo numero di serie non compaia in questa lista.

OCSP - Online Certificate Status Protocol

Protocollo alternativo alla CRL: permette di verificare in tempo reale lo stato di un singolo certificato interrogando un server OCSP della CA, senza dover scaricare l'intera lista.

I certificati nella pratica: HTTPS e il lucchetto

1

Il browser visita un sito HTTPS

Richiede al server il suo certificato digitale

2

Il server invia il certificato

Contiene la sua chiave pubblica, firmata da una CA

3

Il browser verifica il certificato

Controlla che sia valido, non scaduto e firmato da una CA fidata

4

Connessione sicura stabilita

Browser e server scambiano i dati in modo cifrato — appare il 

Il certificato SSL/TLS è la tecnologia alla base di ogni sito sicuro (HTTPS) — lo usi ogni giorno senza saperlo.

La firma digitale e la legge italiana

1997**Legge Bassanini (L. 59/1997)**

Prima legge che attribuisce validità legale ai documenti informatici e agli atti firmati digitalmente.

1999**Direttiva UE 1999/93/CE**

Introduce la firma digitale nella normativa europea, rendendola equivalente a una firma autografa.

2004**D.P.C.M. 13/01/2004**

Stabilisce le regole tecniche per formazione, trasmissione e validazione dei documenti informatici.

2009**CAD & CNIPA Del. 45/2009**

Il Codice dell'Amministrazione Digitale obbliga la PA ad adottare strumenti digitali; fissa gli standard di interoperabilità tra i certificatori.

I concetti chiave da ricordare



Il problema

Non basta avere una chiave pubblica:
bisogna sapere di chi è davvero



Certificato digitale

Associa chiave pubblica e identità,
firmato da una CA di fiducia



CA e PKI

La gerarchia di CA (root → intermedie
→ foglie) garantisce la fiducia



Ciclo di vita

Emissione, rinnovo e revoca
(CRL/OCSP) gestiti dalla Certification
Authority



Nella pratica

HTTPS, firma digitale di documenti e
accesso ai servizi pubblici (CNS/CIE)



Valore legale

La firma digitale equivale a una firma
autografa per legge in tutta l'UE